

SAPA IPB

Proposal Teknis

Fadia Syakira Mustaniroh	G6401231005
Indriyani Khairan Nisa	G6401231044
Muthia Khansa	G6401231123

1. Pendahuluan

1.1 Latar Belakang

Layanan akademik di perguruan tinggi merupakan salah satu komponen penting yang mendukung kelancaran kegiatan belajar mengajar mahasiswa. Di IPB University, mahasiswa kerap menghadapi tantangan dalam mengakses informasi layanan akademik, memahami alur pengajuan layanan, dan memantau status permohonan mereka secara real-time. Kondisi ini mendorong terbentuknya kebutuhan akan sebuah sistem terpusat yang mampu menjembatani mahasiswa dengan unit pelayanan akademik secara efisien dan terstruktur.

SAPA IPB hadir sebagai solusi berbasis web yang memungkinkan mahasiswa mengajukan berbagai permohonan layanan akademik secara daring, berinteraksi dengan chatbot layanan, serta memantau status pengajuan mereka secara langsung. Di sisi lain, staff akademik dapat mengelola dan merespons tiket pengajuan dengan lebih terorganisir melalui portal yang sama.

Mengingat sistem ini mengelola data sensitif mahasiswa seperti Nomor Induk Mahasiswa (NIM), data pribadi, dokumen persuratan digital, dan token autentikasi, penerapan keamanan informasi yang kuat menjadi keharusan. Sistem ini dirancang dengan mengintegrasikan protokol AAA (Authentication, Authorization, dan Accounting) sebagai fondasi keamanannya, memastikan bahwa setiap akses terhadap sistem terverifikasi, terotorisasi sesuai peran, dan tercatat untuk keperluan audit.

1.2 Rumusan Masalah

Berdasarkan latar belakang di atas, permasalahan yang diidentifikasi dalam pengembangan sistem SAPA IPB dari perspektif keamanan informasi adalah sebagai berikut.

- Bagaimana memastikan bahwa hanya pengguna dengan identitas valid dan terdaftar di domain institusi yang dapat mengakses sistem, sehingga risiko akses tidak sah dapat diminimalkan?
- Bagaimana menerapkan kontrol akses berbasis peran (RBAC) agar setiap pengguna hanya dapat mengakses sumber daya dan fitur yang sesuai dengan perannya, mencegah eskalasi hak akses yang tidak sah?
- Bagaimana menjamin keamanan, kerahasiaan, serta integritas data sensitif dari risiko akses tidak sah (*unauthorized access*)?

- d. Bagaimana menjamin integritas dan keaslian dokumen persuratan digital yang dihasilkan sistem sehingga tidak dapat dipalsukan atau dimodifikasi tanpa terdeteksi?
- e. Bagaimana membangun sistem pencatatan aktivitas (*audit log*) yang komprehensif dan tahan manipulasi untuk mendukung akuntabilitas dan investigasi insiden keamanan?

1.3 Tujuan

Tujuan dari pengembangan sistem SAPA IPB dari perspektif keamanan informasi adalah sebagai berikut.

- a. Mengimplementasikan mekanisme autentikasi kuat yang dibatasi pada domain resmi kampus (@apps.ipb.ac.id) dan fitur session timeout otomatis untuk mencegah akses tidak sah.
- b. Menerapkan kontrol otorisasi berlapis menggunakan Role-Based Access Control (RBAC) untuk memastikan setiap pengguna hanya dapat mengakses data dan fitur yang sesuai dengan perannya, serta mencegah serangan Insecure Direct Object Reference (IDOR).
- c. Mengamankan data sensitif mahasiswa menggunakan enkripsi dan hashing.
- d. Memvalidasi integritas dokumen persuratan menggunakan digital signature sebagai bentuk non-repudiation.
- e. Membangun sistem audit logging yang mencatat seluruh aktivitas kritis pengguna secara akurat dan immutable untuk mendukung akuntabilitas sistem dan investigasi insiden keamanan.

1.4 Identifikasi Aset Kritis

Berdasarkan hasil threat modeling yang telah dilakukan, terdapat lima kategori aset kritis dalam sistem SAPA IPB yang memerlukan perlindungan keamanan berlapis. Data pribadi mahasiswa yang mencakup NIM, nama lengkap, alamat, tempat dan tanggal lahir, program studi, dan IPK merupakan aset dengan sensitivitas tertinggi karena bersifat personally identifiable information (PII). Kebocoran data ini dapat berdampak langsung pada privasi mahasiswa dan berpotensi melanggar ketentuan perlindungan data pribadi.

Dokumen persuratan digital seperti surat keterangan mahasiswa aktif, surat izin akademik, dan dokumen resmi lainnya memerlukan jaminan integritas dan non-repudiation. Pemalsuan atau modifikasi dokumen tanpa terdeteksi dapat menimbulkan kerugian serius bagi mahasiswa maupun institusi. Kunci kriptografi yang terdiri dari private key untuk digital signature dan key material untuk enkripsi merupakan aset paling fundamental dalam infrastruktur keamanan sistem. Kompromi terhadap kunci ini dapat mengakibatkan kegagalan seluruh mekanisme keamanan kriptografi yang diterapkan.

Session token berupa JWT dan refresh token digunakan untuk mempertahankan sesi pengguna yang terautentikasi. Token yang berhasil dicuri dapat dieksploitasi untuk melakukan session hijacking, sehingga memerlukan mekanisme rotasi berkala dan masa kadaluarsa yang singkat. Audit log dan accounting records merupakan rekaman seluruh aktivitas sensitif pengguna yang berfungsi sebagai jejak digital forensik. Integritas log harus dijaga dengan ketat karena manipulasi terhadap log dapat menghilangkan bukti penting dalam investigasi insiden keamanan.

2. Tinjauan Pustaka

2.1 Protokol AAA (Authentication, Authorization, dan Accounting)

Protokol AAA merupakan kerangka keamanan yang secara luas diterapkan dalam sistem informasi untuk mengelola akses pengguna secara terstruktur. Weise (2003) dalam dokumen teknis Cisco mendefinisikan AAA sebagai tiga fungsi keamanan yang saling melengkapi: autentikasi memverifikasi identitas pengguna, otorisasi menentukan hak akses pengguna, dan accounting mencatat seluruh aktivitas pengguna dalam sistem. Penerapan protokol AAA secara menyeluruh terbukti efektif dalam memperkuat postur keamanan sistem informasi berbasis web (Stallings, 2017).

2.2 Single Sign-On (SSO) dan OAuth 2.0

Single Sign-On (SSO) adalah mekanisme autentikasi yang memungkinkan pengguna mengakses beberapa sistem dengan satu set kredensial. OAuth 2.0 merupakan protokol otorisasi standar industri yang memfasilitasi akses terbatas ke akun pengguna pada layanan pihak ketiga (Hardt, 2012). Google OAuth 2.0 secara khusus mendukung pembatasan akses berbasis domain melalui parameter *hd* (hosted domain), sehingga memungkinkan sistem membatasi login hanya untuk akun institusional. Penerapan SSO berbasis OAuth 2.0 di lingkungan akademik terbukti meningkatkan keamanan autentikasi sekaligus menyederhanakan pengalaman pengguna (Chadwick & Inman, 2009).

2.3 JSON Web Token (JWT)

JSON Web Token (JWT) adalah standar terbuka (RFC 7519) yang mendefinisikan format token kompak dan mandiri untuk transmisi informasi antar pihak secara aman dalam bentuk objek JSON (Jones et al., 2015). JWT terdiri dari tiga bagian yaitu header, payload, dan signature yang diencode menggunakan Base64URL. Dalam konteks keamanan sistem web, JWT digunakan sebagai mekanisme manajemen sesi stateless yang mengeliminasi kebutuhan penyimpanan sesi di server, namun tetap memastikan integritas klaim yang dibawa token melalui digital signature.

2.4 Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) adalah model kontrol akses yang menetapkan hak akses berdasarkan peran pengguna dalam organisasi, bukan berdasarkan identitas individu. Sandhu et al. (1996) dalam penelitian fundamentalnya mendefinisikan RBAC sebagai model yang menetapkan izin kepada peran, kemudian mengaitkan peran tersebut dengan pengguna, sehingga manajemen hak akses menjadi lebih efisien dan terstruktur. RBAC terbukti efektif dalam mencegah privilege escalation dan serangan IDOR pada sistem informasi akademik yang memiliki hierarki pengguna yang jelas (Ferraiolo et al., 2001).

2.5 Kriptografi: Hashing dan Enkripsi

Hashing adalah fungsi satu arah yang mengubah data input menjadi nilai hash dengan panjang tetap. Algoritma bcrypt yang dikembangkan oleh Provos dan Mazières (1999) dirancang khusus untuk hashing password dengan kompleksitas komputasi yang dapat dikonfigurasi (cost factor), menjadikannya tahan terhadap serangan brute force dan rainbow table. Sementara itu, algoritma AES (Advanced Encryption Standard) yang ditetapkan oleh NIST (2001) merupakan standar

enkripsi simetris yang digunakan secara luas untuk melindungi data sensitif dalam penyimpanan maupun transmisi.

2.6 Digital Signature

Digital signature adalah mekanisme kriptografi yang memungkinkan verifikasi keaslian dan integritas dokumen digital. RSA (Rivest, Shamir, Adleman) merupakan algoritma kunci publik yang paling umum digunakan untuk keperluan digital signature (Rivest et al., 1978). Prinsip non-repudiation yang dijamin oleh digital signature memastikan bahwa pihak yang menandatangani dokumen tidak dapat menyangkal keterlibatannya di kemudian hari, yang merupakan kebutuhan kritis dalam konteks penerbitan dokumen persuratan akademik resmi.

2.7 Audit Logging dan Keamanan Log

Audit logging merupakan praktik pencatatan sistematis terhadap seluruh aktivitas dan kejadian dalam sistem informasi untuk tujuan keamanan, kepatuhan regulasi, dan forensik digital. Menurut Kent dan Souppaya (2006) dalam panduan NIST SP 800-92, log keamanan yang efektif harus mencakup minimal enam elemen yaitu timestamp, identitas pengguna, jenis aksi, objek yang diakses, hasil aksi, dan alamat IP sumber. Keamanan dan immutability log menjadi aspek kritis karena manipulasi log dapat menghilangkan jejak digital yang diperlukan dalam investigasi insiden keamanan.

3. Metodologi

3.1 Analisis Kebutuhan dan Pemodelan Ancaman (*Threat Modeling*)

Tahap awal berfokus pada identifikasi aset informasi kritis dalam ekosistem layanan akademik IPB (seperti data pribadi mahasiswa dan dokumen persuratan). Dilakukan analisis kerentanan (*vulnerability assessment*) dan pemetaan ancaman (*threat modeling*) untuk merancang kebutuhan keamanan (Security Requirement) yang presisi, guna memastikan perlindungan terhadap kerahasiaan, integritas, dan ketersediaan data.

3.2 Perancangan Arsitektur Keamanan

Pada tahap ini, arsitektur basis data dan alur komunikasi jaringan dirancang ulang dengan memasukkan lapisan kriptografi:

- **Keamanan Basis Data:** Modifikasi *Entity Relationship Diagram* (ERD) untuk menetapkan kolom data sensitif yang memerlukan enkripsi menggunakan algoritma AES.
- **Manajemen Kunci (*Key Management*):** Perancangan mekanisme penyimpanan kunci kriptografi secara aman menggunakan *environment variables* untuk mencegah kebocoran kunci (*hardcoding*).

3.3 Implementasi Protokol AAA

Tahap konstruksi utama melibatkan integrasi tiga pilar keamanan ke dalam fungsionalitas SAPA IPB:

1. ***Authentication* (Autentikasi):** Mengimplementasikan otentikasi terpusat memanfaatkan layanan *Google Workspace* (OAuth 2.0) yang membatasi akses hanya untuk pengguna dengan domain resmi institusi (@apps.ipb.ac.id).

2. **Authorization (Otorisasi):** Mengembangkan modul RBAC pada antarmuka pengguna dan logika *backend* sistem, memastikan pembatasan hak akses yang ketat antara peran mahasiswa pemohon dan peran *staff* pemberi layanan.
3. **Accounting dan Non-Repudiation:** Mengembangkan modul *audit log* untuk melacak rekam jejak aktivitas, serta mengimplementasikan fitur Tanda Tangan Digital (*Digital Signature*) menggunakan algoritma RSA pada modul persetujuan (*approval*) dokumen persuratan untuk memastikan dokumen bersifat nirsangkal dan valid.

3.4 Pengujian Kinerja dan Keamanan Sistem

Tahap akhir melibatkan uji coba sistem secara menyeluruh (*End-to-End Security Test*). Pengujian mencakup validasi fungsionalitas keamanan, uji ketahanan terhadap injeksi akses tidak sah, serta analisis kuantitatif kinerja sistem (komparasi *performance overhead* pada waktu respons sistem sebelum dan sesudah algoritma enkripsi diterapkan). Hasil analisis pengujian ini akan diolah menjadi laporan teknis dan naskah publikasi ilmiah.

4. Referensi

- Chadwick, D. W., & Inman, G. (2009). Attribute aggregation in federated identity management. *Computer*, 42(5), 33-40.
- Ferraiolo, D. F., Sandhu, R., Gavrila, S., Kuhn, D. R., & Chandramouli, R. (2001). Proposed NIST standard for role-based access control. *ACM Transactions on Information and System Security*, 4(3), 224-274.
- Hardt, D. (2012). *The OAuth 2.0 Authorization Framework* (RFC 6749). Internet Engineering Task Force.
- Jones, M., Bradley, J., & Sakimura, N. (2015). *JSON Web Token (JWT)* (RFC 7519). Internet Engineering Task Force.
- Kent, K., & Souppaya, M. (2006). *Guide to Computer Security Log Management* (NIST SP 800-92). National Institute of Standards and Technology.
- National Institute of Standards and Technology. (2001). *Advanced Encryption Standard (AES)* (FIPS PUB 197). U.S. Department of Commerce.
- Provos, N., & Mazières, D. (1999). A future-adaptable password scheme. *Proceedings of the USENIX Annual Technical Conference*, 81-91.
- Rivest, R. L., Shamir, A., & Adleman, L. (1978). A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM*, 21(2), 120-126.
- Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. *Computer*, 29(2), 38-47.
- Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice* (7th ed.). Pearson.
- Weise, J. (2003). *Public Key Infrastructure Overview*. Sun Microsystems.